

Reconnaissance & OSINT

Passive vs Active Recon

Passive â€” collect info WITHOUT touching the target (never triggers alerts): WHOIS, DNS, search engines, GitHub, public records

Active â€” touch the target: port scans, HTTP requests, banners

Always start passive.

The OSINT Toolkit

```
# WHOIS â€” who owns the domain, when registered
whois example.com

# DNS enumeration
dig example.com any
dig example.com txt    # SPF/DKIM (authentication posture!)
dig -x 8.8.8.8         # reverse lookup

# Subdomain brute-force (with wordlist)
# subfinder -d example.com
# amass enum -d example.com
```

Search-Engine OSINT (Google Dorks)

Google dorks find exposed files and web pages:

```
site:example.com filetype:pdf
site:example.com intitle:"index of"    # open directory listings
site:example.com inurl:admin
site:example.com "password" "config"
```

GitHub & Code OSINT

Search public repos: `api. / key. / token / secret`

Git history contains old secrets â€” `git log`, or grep the clone for leaked keys

Employee GitHub = org tech stack hints

Sinai example: the Uber 2016 breach â€” an employee's converged GitHub commit with an AWS key.

Metadata & Shodan

Exif in photos (location, device)

Shodan â€” searchable index of exposed services on the internet ("camera with default login on port 21")

Scans: 0.0.0.0/0; queries by service/server type

Social & Human OSINT

LinkedIn â†’ employees, roles, org chart

Job listings â†’ tech stack (which software/certs) â†’ vulnerability targeting

Breach dumps â†’ reused passwords (correlate with the target's domains)

Social media â†’ phishing personas (module 09)

Document Everything

OSINT is a **dossier-building** exercise. Analysts and pentesters keep the findings structured:

Domains & IPs

Services & version (â†’ CVEs)

Known accounts

Leaked credentials (scope-specific)

People, org, tech stack draws

Ethics: OSINT on a target is legal *passive* research â€” as long as you don't touch systems without authorization and you stay within friendly engagements. Never cross into active probing without scope.

[← Pentesting Methodology & RuL...](#)

[Scanning & Vulnerability Disco...](#)